

방송미디어통신위원회 소관 주요정보통신기반시설 보호지침

제정 2016. 06. 14. 방송통신위원회 훈령 제211호

개정 2019. 05. 15. 방송통신위원회 훈령 제269호

개정 2026. 2. 27. 방송미디어통신위원회 훈령 제22호

제1장 총 칙

제1조(목적) 이 지침은 「정보통신기반 보호법」(이하 "법"이라 한다) 제10조에 따라 방송미디어통신위원회위원장(이하 "위원장"이라 한다)이 관할하는 주요정보통신기반시설을 각종 침해행위로부터 보호하기 위하여 해당 주요정보통신기반시설 관리기관의 장(이하 "관리기관의 장"이라 한다)이 준수하여야 할 정보보호에 관한 구체적 사항을 정함을 목적으로 한다.

제2조(용어의 정의)

① 이 지침에서 사용하는 용어의 정의는 다음과 같다.

1. "주요정보통신기반시설 보호대책"이라 함은 법 제5조제1항에 따라 각 관리기관의 주요정보통신기반시설을 안전하게 보호하기 위해 예방, 백업, 복구 등 물리적·기술적 대책을 포함한 관리기관별 보호대책을 말한다.
2. "주요정보통신기반시설 보호계획"이라 함은 법 제6조의 규정에 의하여 관리기관으로부터 제출받은 주요정보통신기반시설보호대책을

종합·조정한 방송미디어통신위원회 소관 주요정보통신기반시설에 관한 보호계획을 말한다.

3. "정보공유·분석센터"라 함은 법 제16조에 따라 분야별 주요정보통신기반시설을 보호하기 위해 취약점 및 대응방안에 관한 정보 제공, 실시간 경보·분석체계 운영 등을 수행하는 조직을 말한다.

② 이 지침에서 사용하는 용어의 정의는 제1항에서 정한 것을 제외하고는 정보통신기반보호법에서 정하는 바에 따른다.

제3조(적용범위) 이 지침은 법 제8조에 따라 지정된 주요정보통신기반시설을 관리하는 기관(이하 "관리기관"이라 한다)과 해당 주요정보통신기반시설을 관리·운용하는 업무종사자에 적용한다.

제4조(보호대책의 수립) ① 관리기관의 장은 법 제5조제1항에 따라 수립한 소관 주요정보통신기반시설 보호대책(이하 "보호대책"이라 한다)을 매년 8월말까지 위원장에게 제출하여야 한다.

② 보호대책에는 다음 각 호의 사항이 포함되어야 한다.

1. 소관 주요정보통신기반시설 보호의 목적 및 대상시설
2. 정보보호체계 및 관리 대책
3. 취약점 분석·평가 및 조치 결과
4. 침해사고 예방 대책
5. 침해사고 대응 및 복구 대책

6. 그 밖에 소관 주요정보통신기반시설의 보호를 위하여 필요한 사항

③ 관리기관의 장은 법 제9조에 따라 실시한 취약점 분석·평가의 결과를 반영하여 보호대책을 수립하여야 한다. 다만, 관리기관의 장은 제16조제1항에 따른 자체 점검을 실시한 경우에는 그 실시한 결과를 함께 반영하여야 한다.

제5조(보호대책 이행점검) ① 위원장은 법 제6조에 따른 보호계획을 수립하기 위해 전년도 보호대책을 제출·이행한 관리기관을 대상으로 해당 보호대책에 대한 이행점검을 실시할 수 있다.

② 위원장은 직접 이행점검을 실시하거나 관리기관으로 하여금 자체적으로 이행점검을 한 후 그 결과를 위원장에게 제출하도록 할 수 있다.

제2장 정보보호체계 및 관리

제6조(정보보호책임관 등) ① 「정보통신기반 보호법 시행령」(이하 "영"이라 한다) 제11조1항에 따른 방송미디어통신위원회 정보보호책임관은 방송미디어통신위원회 기획조정관의 정보보호에 관한 사무를 담당하는 팀장으로 한다.

② 정보보호책임관은 위원장이 관할하는 소관분야의 모든 주요정보통신기반시설의 보호에 관한 업무를 총괄한다.

③ 정보보호책임관은 다음 각 호의 업무를 수행한다.

1. 주요정보통신기반시설보호계획의 수립·시행에 관한 업무
2. 주요정보통신기반시설의 지정 및 지정취소에 관한 업무
3. 주요정보통신기반시설 보호지침의 제정·수정 및 보완에 관한 업무
4. 정보보호 조직·체계의 구축·운영에 관한 업무
5. 취약점 분석·평가 및 침해사고의 피해확산 방지와 신속한 대응을 위하여 필요한 조치 업무
6. 소요 예산 및 시설·장비 등 자산의 확보에 관한 업무
7. 그 밖에 소관분야 주요정보통신기반시설의 보호를 위하여 위원장이 지시하는 사항

제7조(정보보호추진체계) ① 정보보호책임관은 영 제11조제2항에 따른 정보보호업무의 총괄 수행을 위해 협의회를 구성·운영할 수 있다.

② 제1항에 따른 협의회의 장은 방송미디어통신위원회 소속 공무원으로 하고, 간사는 제6조에 따른 정보보호책임관으로 하며, 한국인터넷진흥원 또는 정보통신분야 정보공유·분석센터의 팀장급 이상 담당자, 관계 전문가 등을 위원으로 구성한다.

③ 제1항에 따른 협의회는 다음 각 호의 업무를 수행한다.

1. 주요정보통신기반시설의 지정 심의·조정
2. 법 제5조제2항에 따라 제출받은 보호대책 분석, 이행점검 및 필요한 조치사항 권고
3. 제6조제3항 각 호의 업무 수행 지원

④ 위원장은 원활한 업무 수행을 위하여 필요한 경우에는 영 제12조 각호에 해당하는 기관 또는 업체에게 제3항의 업무 중 일부를 위임할 수 있으며, 필요한 행정적·기술적 지원을 요청할 수 있다.

⑤ 영 제12조각호에 해당하는 기관 또는 업체의 장은 제4항에 따라 위임받은 업무를 수행하기 위하여 아래사항과 관련한 실무조정반을 구성·운영할 수 있다.

1. 주요정보통신기반시설 보호계획(이하 "보호계획"이라 한다) 및 보호대책 검토
2. 주요정보통신기반시설의 지정 및 취소, 지정 범위 조정 검토

3. 주요정보통신기반시설 보호 관련 제도 개선
4. 보호대책 이행점검 결과에 따른 후속조치 및 이행률 제고방안
5. 주요정보통신기반시설 점검에 따른 미흡사항 조치방안
6. 주요정보통신기반시설 침해사고 예방 및 대응조치
7. 그 외 주요정보통신기반시설 보호와 관련하여 협의가 필요한 사항 등

제8조(정보보호책임자) ① 법 제5조제4항에 따라 관리기관의 장의 지정을 받은 정보보호책임자는 관리기관의 장이 관할하는 주요정보통신기반시설의 보호에 관한 업무를 총괄한다.

② 정보보호책임자는 다음 각 호의 업무를 수행한다.

1. 소관 주요정보통신기반시설 보호대책의 수립에 관한 업무
2. 소관 주요정보통신기반시설의 설치 및 관리·운영에 대한 보호측면의 지도·감독에 관한 업무
3. 취약점 분석·평가 및 침해사고 예방에 관한 업무
4. 침해사고 대응 및 복구에 관한 업무
5. 소요 예산 및 시설·장비 등 자산의 확보에 관한 업무
6. 그 밖에 소관 주요정보통신기반시설의 보호를 위하여 관리기관의 장이 지시하는 업무

③ 관리기관의 장은 정보보호책임자를 지정한 때에는 그 사실을 위원장에게 통지하여야 한다.

④ 정보보호책임자는 소관 주요정보통신기반시설과 다른 주요정보

통신기반시설의 보호를 위하여 정보보호책임관과 긴밀히 협조하여야 한다.

제9조(전담 조직의 구성) ① 관리기관의 장은 정보보호에 관한 다음 각 호의 업무를 수행하기 위하여 필요하다고 인정하는 때에는 정보보호책임자 소속 하에 별도의 전담 조직을 구성·운영할 수 있다.

1. 주요정보통신기반시설 보호대책의 수립·시행
2. 제21조 및 제22조에 따른 침해사고의 대응 및 복구에 필요한 기술적 지원의 요청
3. 취약점 분석·평가 및 전담반 구성
4. 주요정보통신기반시설의 보호에 필요한 조치명령 또는 권고의 이행
5. 침해사고의 통지
6. 주요정보통신기반시설의 보호업무에 관한 사항

② 관리기관의 장은 관리기관에 소속되지 아니한 자로서 정보보호에 관한 전문지식이 있는 인력 및 영 제12조각호에 해당하는 기관 또는 업체 인력이 전담 조직에 참여하게 할 수 있다.

③ 관리기관의 장은 제1항에 따른 전담 조직의 구성 및 운영에 필요한 사항을 정하여야 한다.

제10조(업무종사자의 준수사항) ① 관리기관의 장은 소관 주요정보통신기

반시설을 관리·운영하는 업무종사자(계약직을 포함한다)로 하여금 다음 각 호의 사항을 준수하도록 하여야 한다.

1. 주요정보통신기반시설의 보호책임에 관한 사항
2. 비밀유지 및 비밀서약에 관한 사항
3. 주요정보통신기반시설 보호관련 법령 및 지침 등의 준수에 관한 사항
4. 보호관련 지침 및 보호조치 위반에 따른 징계에 관한 사항

② 관리기관의 장은 해당 시설을 관리·운영하는 업무종사자가 보직이 변경되거나 퇴사하는 경우 법 제27조에 따라 소관 주요정보통신기반시설의 관리·운영에 관하여 취득한 비밀을 외부에 유출하지 않도록 주지시켜야 한다. 이 경우 관리기관의 장은 보직이 변경되거나 퇴사하는 자로 하여금 비밀유지에 관한 서약서를 작성하도록 해야 한다.

제11조(보호업무등의 위탁) ① 관리기관의 장은 소관 주요정보통신기반시설의 관리·운영 또는 제16조에 따른 점검 등 보호에 관한 업무 일부와 법 제9조제3항에 따른 취약점 분석·평가 업무를 다음 각 호의 기관 또는 업체에 위탁할 수 있다.

1. 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제52조에 따른 한국인터넷진흥원
2. 법 제16조에 따른 정보공유·분석센터
3. 「정보보호산업의 진흥에 관한법률」 제23조에 따라 지정된 정보보

호 전문서비스 기업

4. 「정부출연연구기관 등의 설립·운영 및 육성에 관한 법률」 제8조

에 따른 한국전자통신연구원

- ② 제①항의 위탁업무 수행에 참여하는 종사자에게 법 제27조에 따른 비밀유지의무를 준수하도록 비밀유지 서약서의 작성 요구, 업무관련 기록·자료의 안전한 보존 및 폐기 등 필요한 조치를 하여야 한다.

제12조(유관기관과의 협조) 관리기관의 장은 소관 주요정보통신기반시설의 보호를 위하여 방송미디어통신위원회, 한국인터넷진흥원, 정보통신분야 정보공유·분석센터 또는 다른 관리기관과 다음 각 호의 사항에 관하여 상호 협조할 수 있다.

1. 주요정보통신기반시설의 보호와 관련된 정보의 공유
2. 침해사고 예방·대응 및 복구를 위한 상호협력 및 지원
3. 그 밖에 소관 주요정보통신기반시설의 보호를 위하여 상호협력이 필요한 사항

제13조(정보보호 교육·훈련의 실시) ① 관리기관의 장은 소관 주요정보통신기반시설을 관리·운영하는 업무종사자를 대상으로 해당 시설의 보호를 위하여 필요한 교육·훈련을 매년 1회 이상 실시하여야 한다. 다만, 소관 주요정보통신기반시설의 보호를 위한 중요한 절차

및 방법 등의 변경이 있거나 신규로 직원을 채용한 때에는 지체 없이 필요한 교육·훈련을 실시하여야 한다.

② 관리기관의 장은 제1항에 따른 훈련을 실시하는 때에는 외부의 정보보호관련 전문기관에 이를 위탁하여 실시할 수 있다.

③ 관리기관의 장은 제1항에 따른 교육·훈련을 실시하기 위하여 다음 각 호의 사항을 정하여야 한다.

1. 교육·훈련의 내용 및 방법
2. 교육·훈련에 관한 기록유지 및 인사관리에 관한 사항
3. 그 밖에 교육·훈련을 위하여 필요한 사항

제14조(정보보호 활동 지원) ① 위원장은 주요정보통신기반시설 및 주요정보통신기반시설과 연계된 시설의 안정성 및 신뢰성을 위하여 관리기관에 대하여 다음 각 호의 사항을 지원할 수 있다.

1. 모의 해킹을 통한 취약점 분석 및 그 조치방안에 대한 지원
2. 보호대책 수립·이행에 대한 지원
3. 관계기관 비상연락체계 구축 및 사이버공격 발생 시 대응·복구 지원
4. 그 밖에 주요정보통신기반시설 보호를 위하여 지원이 필요한 사항

제3장 취약점 분석·평가 및 침해사고 예방

제15조(취약점 분석·평가) ① 관리기관의 장은 법 제9조에 따라 소관 주요정보통신기반시설에 대한 최초 취약점 분석·평가를 실시한 때에는 1년을 주기로 실시하여야 한다.

② 관리기관의 장은 제1항에도 불구하고 소관 정보통신기반시설이 주요정보통신기반시설로 새로이 지정된 경우에는 6개월 이내에 취약점 분석·평가를 실시하여야 한다. 다만, 관리기관의 장은 지정된 후 6개월 이내에 취약점 분석·평가를 시행하지 못할 특별한 사유가 있는 경우에는 위원장의 승인을 받아 지정 후 9개월 이내에 실시하여야 한다.

③ 관리기관의 장은 법 제9조제4항에 따른 취약점 분석·평가에 관한 기준을 고려하여 취약점 분석·평가의 대상, 기간, 절차, 방법, 소요예산 편성 및 집행 등 취약점 분석·평가를 구체적으로 시행하기 위하여 필요한 계획을 수립·시행하여야 한다.

④ 관리기관의 장은 법 제9조제2항에 따른 전담반을 구성하는 때에는 정보보호책임자를 반장으로 하고, 취약점 분석·평가의 실효성 및 객관성을 확보할 수 있도록 주요정보통신기반시설 관리·운영 업무 종사자와 정보보호에 관한 전문성을 가진 자로 구성하여야 한다. 이 경우 관리기관의 장은 소관 주요정보통신기반시설의 특성 및 취약점 분석·평가 기준을 고려하여 필요한 전문인력을 미리 확보하여야 한다.

⑤ 관리기관의 장은 법 제9조제3항에 따라 취약점 분석·평가를 외부에 위탁하여 실시하는 때에는 소속 전담반이 함께 참여하도록 하여야 한다.

제16조(자체점검 및 수시점검) ① 관리기관의 장은 영 제17조에 따라 취약점 분석·평가가 필요하다고 판단되는 경우에는 1년이 되지 아니한 때에도 소관 주요정보통신기반시설에 대한 자체 점검을 실시할 수 있다.

② 관리기관의 장은 제1항에 따른 자체 점검을 실시하는 때에는 다음 각 호의 사항을 고려하여 실시하여야 한다.

1. 법 제9조에 따른 취약점 분석·평가의 기준, 절차 및 방법
2. 이전에 실시한 취약점 분석·평가의 결과
3. 점검 기간 및 소요예산

③ 관리기관의 장은 다음 각 호의 어느 하나에 해당하는 경우에는 수시로 점검(이하 "수시점검"이라 한다)을 실시할 수 있다.

1. 침해사고의 징후가 있는 경우
2. 시설·장비의 교체 및 보수를 한 경우
3. 침해사고에 따른 복구조치를 한 경우
4. 소관 주요정보통신기반시설의 보호에 관한 절차·방법 및 담당 인력의 변경이 있는 경우

④ 관리기관의 장은 제1항부터 제3항까지의 규정에 따른 점검을 실시한

때에는 점검 기간, 대상, 방법 및 결과 등 점검에 관한 제반사항을 기록·관리하여야 한다.

제17조(보완조치) ① 관리기관의 장은 제15조에 따른 취약점 분석·평가 및 제16조에 따른 점검실시 결과를 반영하여 다음 각 호의 조치(이하 "보완조치"라 한다)를 하여야 한다.

1. 이 지침에 따라 수립된 각종 보호조치, 절차 및 방법 등의 재검토 및 수정·보완

2. 시설·장비의 구축·보수 또는 설치

3. 그 밖에 분석·평가 또는 점검 결과를 반영한 보완 조치

② 관리기관의 장은 보완조치를 하는 때에는 정보화관련 예산 또는 기본사업비 예산을 활용하여 보완조치에 필요한 경비를 우선 집행하여야 한다.

③ 관리기관의 장은 보완조치가 미흡하거나 추가적으로 보완조치가 필요한 때에는 해당 보완조치에 소요되는 비용을 다음 연도 예산에 반영하여야 한다.

제18조(침해사고 예방조치) ① 관리기관의 장은 소관 주요정보통신기반시설을 보호하기 위하여 다음 각 호의 사항을 포함하는 예방조치를 하여야 한다.

1. 관리·운영절차의 수립

2. 제한구역의 설정

3. 장비·시설의 설치·유지 및 보수

4. 기타 소관 주요정보통신기반시설의 보호에 필요한 사항

② 관리기관의 장은 소관 주요정보통신기반시설을 보호하기 위하여 정보보호시스템 및 정보보호용 컴퓨터프로그램의 설치·운용에 관하여 필요한 조치를 하여야 한다.

③ 관리기관의 장은 컴퓨터바이러스의 유입으로 인한 소관 주요정보통신기반시설 피해를 방지하기 위하여 컴퓨터바이러스 백신프로그램의 배포·갱신 등 필요한 조치를 하여야 한다.

④ 관리기관의 장은 안전한 정보유통을 위하여 소관 주요정보통신기반시설 관리·운영 업무종사자로 하여금 안전한 인증수단 적용 등 필요한 조치를 하여야 한다. 이 경우 관리기관의 장은 소관 주요정보통신기반시설을 이용하여 정보를 유통하는 자가 있는 경우에는 해당 이용자에게 안전한 인증수단 이용을 권고하여야 한다.

⑤ 관리기관의 장은 소관 주요정보통신기반시설에 대한 권한 없는 자의 부당한 접근 및 이용을 방지하기 위하여 필요한 조치를 하여야 한다.

⑥ 관리기관의 장은 제1항부터 제5항까지의 규정에 따른 조치를 하는 때에는 별표 1에서 정하는 사항을 고려하여야 한다.

제19조(외부 정보통신망 연결에 따른 보호조치) 관리기관의 장은 소

관 주요정보통신기반시설을 다른 기관 또는 업체와 정보통신망으로 연결하는 경우에는 해당 업체 또는 기관이 관리기관의 다음 각 호에 해당하는 조치, 절차 및 방법을 준수·협조하도록 필요한 약정을 체결하여야 한다.

1. 제18조에 따른 침해사고 예방을 위한 조치, 절차 및 방법
2. 제20조부터 제22조까지의 규정에 따른 침해사고 대응 및 복구를 위한 조치, 절차 및 방법

제4장 침해사고 대응 및 복구

제20조(연락체계의 구축) ① 관리기관의 장은 소관 주요정보통신기반시설에 대한 침해사고가 발생한 경우 신속히 대응하고 관계기관에 알리기 위하여 필요한 연락체계를 구축하여야 한다.

② 관리기관의 장은 제1항에 따른 연락체계에 있어 방송미디어통신위원회와 한국인터넷진흥원, 정보통신분야 정보공유·분석센터의 장이 포함되도록 하여야 한다.

제21조(침해사고 대응조치) ① 관리기관의 임직원과 위탁기관·업체의 위탁업무 수행에 참여하는 종사자는 제10조에 따른 침해사고의 징후가 있거나 침해사고의 발생을 인지한 때에는 이를 즉시 정보보호책

임자에게 보고하여야 한다.

② 정보보호책임자는 소관 주요정보통신기반시설에 대한 중대한 침해사고의 발생·징후를 보고 받거나 인지한 때에는 이를 방송미디어통신위원회에 즉시 보고하고 필요한 응급조치를 하여야 한다. 다만, 관리기관의 장은 소관 주요정보통신기반시설의 교란, 마비 또는 파괴가 일어나지 아니하는 등 경미한 침해사고의 발생·징후는 보고하지 아니할 수 있다.

③ 관리기관의 장은 제1항 및 제2항에 따른 사항을 포함하여 침해사고 발생에 따른 대응절차 및 방법에 관하여 필요한 사항을 정하여야 한다. 이 경우 별표 2에서 정하는 사항을 고려하여야 한다.

④ 관리기관의 장은 방송미디어통신위원회가 권고하는 침해사고 대응요령에 따라 피해사실의 보고 및 긴급대응조치 등을 하여야 한다.

제22조(복구조치) ① 관리기관의 장은 침해사고로 인하여 소관 주요정보통신기반시설이 파괴되거나 기능이 제대로 수행되지 아니하는 때에는 해당 시설이 정상적으로 가동될 수 있도록 필요한 복구조치를 신속히 취하여야 한다. 이 경우 관리기관의 장은 방송미디어통신위원회 또는 법 제13조에 따른 관계 행정기관, 수사기관 또는 한국인터넷진흥원의 장, 정보통신분야 정보공유·분석센터의 장 등에게 복구에 필요한 지원을 요청할 수 있다.

② 관리기관의 장은 제1항의 복구조치를 위하여 필요한 조직, 자

원, 외부기관과의 협력 등을 포함하는 복구지원체계를 구축하여야 한다.

③ 관리기관의 장은 제1항 및 제2항의 내용을 포함하여 침해사고가 발생한 시설에 대한 복구절차 및 방법에 관하여 필요한 사항을 정하여야 한다. 이 경우 별표 2에서 정하는 사항을 고려하여야 한다.

제23조(대응·복구 훈련의 실시) ① 관리기관의 장은 소속 임직원과 제10조에 따른 기관 또는 업체의 위탁업무 수행에 참여하는 종사자에게 제21조제3항 및 제22조제3항에 따른 침해사고 대응·복구에 관한 절차 및 방법을 정확히 숙지할 수 있도록 필요한 훈련(이하 "대응·복구 훈련"이라 한다)을 정기적으로 실시하여야 한다. 이 경우 관리기관의 장은 필요하다고 인정하는 때에는 다른 관리기관과 공동으로 훈련을 실시할 수 있다.

② 관리기관의 장은 대응·복구 훈련을 실시한 결과 필요하다고 인정하는 때에는 해당되는 대응·복구 절차 및 방법을 수정·보완하여야 한다.

제24조(해킹·바이러스 예방의 날) ① 관리기관의 장은 매월 세 번째 수요일을 해킹·바이러스 예방의 날로 운영한다.

② 관리기관의 장은 해킹·바이러스 예방의 날에 다음 각 호에 해당하는 업무를 수행한다.

1. 제13조 및 제23조에 따른 교육·훈련의 실시
2. 컴퓨터 바이러스 점검 등 필요한 점검의 실시

제5장 보칙

제25조(재검토기한) 「훈령·예규 등의 발령 및 관리에 관한 규정」에 따라 법령이나 현실여건의 변화 등을 검토하여 2019년 7월 1일 기준으로 매 3년이 되는 시점(매 3년째의 6월 30일까지를 말한다)마다 이 훈령의 폐지, 개정 등 조치를 하여야 한다.

부칙<제211호, 2016. 6. 14.>

이 지침은 발령한 날부터 시행한다.

부칙<제269호, 2019. 5. 15.>

이 훈령은 발령한 날부터 시행한다.

부칙<제22호, 2026. 2. 27.>

이 훈령은 발령한 날부터 시행한다.

<별표 1>

침해사고 예방조치시 고려사항(제18조 관련)

가. 관리·운영 측면의 고려사항

구 분	주요 고려 사항
관리·운영절차	○ 관리·운영절차의 수립시 고려사항 - 시스템 문제발생시 재동작 및 복구 절차 - 시스템 모니터링 방안 - 중요 산출물에 대한 관리 방안 - 업무수행시 발생될 예외사항 및 오류사항 처리 방안 - 정보처리 및 취급 절차
제한구역 설정 및 보호	○ 제한구역 설정시 고려 사항 - 보호대상 설정 - 특히 중요한 시설이나 장비는 제한구역으로 설정 - 출입 통제 방안 - 반출·입 물품에 대한 기록 유지 - 정전대비 별도의 전원 공급 시설
장비·시설의 도입 및 설치	○ 시스템 구입 및 설치시 일반적 고려 사항 - 현재 시스템의 성능과 가용능력의 한계에 대한 분석 - 시스템의 기능적, 운영적 요구사항 정의 및 시기의 예측 - 기존 시스템과의 적합성 확보 - 정보보호 시스템의 설치시는 보호치침과의 부합성 및 설치 필요성에 대하여 검증 - 정기적인 점검 및 안전성에 대한 재검토 ○ 정보보호시스템 도입 및 설치·운영시 고려 사항 - 요구사항 파악 - 도입·설치의 목적 - 성능 및 도입·설치의 타당성에 대한 검토 - 관리의 편의성 - 로그관리의 편의성 - 정보보호시스템에 대한 로그 감시 기능

구 분	주요 고려 사항
변경관리 절차	○ 장비, 소프트웨어, 절차들의 변경사항에 대한 관리 책임 및 절차 수립시 고려사항 - 주요 변경사항 및 변경대상에 관한 정의·기록 유지 - 변경 실패에 따른 복구나 폐기에 대한 책임 정의 절차 - 변경에 대한 잠정적인 영향 평가 - 요구된 변경사항에 대한 승인절차 - 모든 관련자에게 변경사항에 대한 공지 및 교육
로그 관리	○ 운영자 로그관리방안 수립시 고려사항 - 시스템 시작, 종료시간, 사용자 인증실패, 접속시도, 시스템 에러 및 수정 내용 등에 대한 로그 유지 - 로그 기록 방법, 대상, 보존 기간, 백업 등 - 주기적 로그 점검 및 방법 - 접근기록에 대한 정기적 분석 및 불법시도에 대한 조치 방법 - 보안 로그 기록 점검사항에 대한 주기적 보고 ○ 정보보호시스템의 로그 기록시 필수 고려사항 - 성공적이거나 거부된 접속 - 정보보호시스템 구성요소로부터의 에러 메시지 - 다중 접근 시도 - 불안한 포트로의 접근 - 로그를 저장할 메모리 - 기록이 멈추게 되지 않도록 사전 대책 강구
장애 관리	○ 장애관리시 고려사항 - 장애의 감지 및 복구를 위해 운영상황 감시 기능 설정 - 장애관리 보고 절차 수립 - 장애시 전체시스템에 대한 피해 최소화를 위해 장애차단 기능 설정 - 장애 복구 기능 설정 - 장애처리후 로그에 대한 재점검으로 장애의 완전 복구상태 확인

구 분	주요 고려 사항
저장매체 관리	○ 테이프, 디스켓, 출력보고서 등의 저장매체 관리시 고려 사항 - 저장매체에 대한 목록관리, 분류, 접근통제, 보관장소, 보관기간, 보관절차 등 수립 - 저장매체에 대한 복사, 변경, 배포, 폐기 방안 - 저장매체 정보저장, 취급 및 전달 절차 수립 - 저장매체 사용에 대한 허가, 점검 수립 및 기록유지 - 저장매체 저장 내용 삭제·폐기 절차
악의적 소프트웨어 관리	○ 컴퓨터바이러스 등 악의적 소프트웨어로부터의 보호를 위한 통제·탐지 조치시 고려 사항 - 사용자에게 바이러스의 위험성에 대한 인식 필요 - 비인가 및 불법 소프트웨어 사용금지 - 알려진 바이러스 백신프로그램 사용 - 지속적인 바이러스 백신프로그램 업데이트 및 검사 - 검증되지 않은 저장매체는 사용전에 검사 - 외부 네트워크나 매체로부터 파일 또는 소프트웨어 다운로드시 대책 마련
백 업	○ 시스템, 데이터, DB 등 정보자산에 대한 백업조치시 고려 사항 - 정보자산에 대한 장애 대비 백업 및 복구 절차 규정 - 데이터의 중요도에 따른 백업 대상, 백업 방식, 백업주기, 백업 기준 등을 설정 - 자연재해로부터 보호받을 수 있는 안전한 장소에 대한 지정 - 주기적으로 백업 받은 데이터에 대한 복구 테스트 실시 - 중요정보에 대하여는 제3의 장소 등 물리적으로 분리된 곳에 백업데이터 보관

나. 기술적 측면에서의 고려사항

구 분	주요 고려 사항
사용자 관리	○ 사용자 계정 관리시 고려 사항 - 시스템 접근에 대한 공식적인 사용자 등록 및 해지 절차 수립 - 주기적으로 인가된 사용자 여부 및 접근권한 점검 - 사용자의 공식적인 로그를 보관 - 동일사용자 계정의 다른 사용자 계정 재발급 방지 - 시스템 관리자가 일반 업무시 일반 사용자 계정 사용
패스워드 관리	○ 패스워드 관리시 고려사항 - 책임추적성을 위해 패스워드 할당 - 패스워드의 안전한 보관 - 패스워드의 노출가능성이 있으면 즉시 변경 - 패스워드 설정시 기피해야 할 요건 · 특정 달, 요일, 머리 글자, 주민등록번호, 자동차번호 · 회사이름, 전화번호 또는 비슷한 숫자 그룹 · 2개 이상의 연관된 신원확인 가능 문자, 숫자, 영문 알파벳 그룹 - 주기적으로 패스워드를 변경, 지난 패스워드 사용금지 - 특별권한이 부여된 ID의 패스워드는 정기적으로 점검 - 첫 로그인시 임시 패스워드는 변경 - 비밀번호 오류 횟수의 제한
네트워크 접근 통제	○ 네트워크 접근 통제시 고려 사항 - 네트워크로 접근하는 사용자에 대한 인가 절차 - 원격접속 사용자 인가 절차 - 비인가된 접근을 막기 위해 서비스 경로의 제한 및 분리 - 관계회사 등과 네트워크 공유시에는 물리적 또는 논리적으로 분리 - 원격 장비의 관리를 위한 책임 및 절차를 수립 - 개발업무 네트워크와 다른 업무용 네트워크와의 분리 운영 - 인증, 암호 활용을 통한 원격 접속 사용자에게 대한 접근통제 - 네트워크를 통해 시스템 운영시 시스템 관리는 원칙적으로 내부 특정 단말로 제한

<별표 2>

침해사고 대응 및 복구 조치시 고려사항(제21조 및 제22조 관련)

구 분	주요 고려 사항
침해사고 대응·복구 절차 및 방법	○ 침해사고에 대한 복구 절차 및 방법 수립시 고려 사항 - 침해사고의 정의 및 범위 - 긴급연락체계 구축 - 침해사고 발생시 대응 요령 및 절차 - 침해사고 복구조직 구성 - 침해사고 복구 장비 및 자원 조달 - 침해사고 대응 및 복구 훈련 실시 사항
침해사고 보고	○ 침해사고 보고시 고려 사항 - 침해 날짜와 시간 - 침해 사고 보고자 및 보고 일시 - 침해 사고 내용 - 침해 사고 대응 내역
침해사고 발생시 응급 조치	○ 침해사고 발생후 응급 조치시 고려사항 - 손상된 시스템은 동작을 즉시 정지 - 내부망의 외부 접속을 즉시 차단 - 긴급복구가 즉시 수행되어야 하는 곳은 정보보호 전문가에 의한 침입탐지 및 복구
침해사고 복구	○ 침해사고 복구시 고려사항 - 사고원인의 분석 및 정의 - 필요한 경우, 재발을 방지하기 위한 대책의 수립 및 시행 - 정보자원 및 시스템 백업을 통한 시스템 재구축 방법 - 시스템 및 정보통신망에 대한 취약점 제거